浏览器注入研究说明

非官方中文研究资料 · 0.3 · 来源与许可逐篇注明

目录

1 浏览器提示词注入：从文本风险到状态变化 **2**

1.1 代理让错误多了一个出口 2

1.2 自适应攻击的分母是什么 2

1.3 把防线拆成可检验条件 3

1.4 我们的实际权限与误拒实验 3

1.5 一个可复核浏览器研究协议 3

参考文献 **4**

1 浏览器提示词注入：从文本风险到状态变化

来源为 Anthropic 2025-11-24 的官方研究说明 [1]。以下为原创分析、模型与实验设计，不是全文翻译；未取得开放改编许可的原文和图不镜像。讨论该发布日期的实验，不将其当成 2026 年现行产品保证。

1.1 代理让错误多了一个出口

聊天模型可以回答错误。浏览器代理还可能把回答转成点击、表单、文件访问或发送动作。外部页面原本只是任务资料；如果其文字被当成行动命令，资料就跨越了权威边界。仅把某个危险词删除不能建立边界，因为攻击可以改写措辞，而正常任务也可能需要阅读危险内容。

用 (o_t, a_t, s_t) 表示第 t 步的观察、动作和外部状态。代理先依据观察和历史生成提案 $a_t = \pi(o_{\le t}, a_{<t})$，执行器再决定是否允许并得到 $s_{t+1} = F(s_t, a_t)$。需要分别检验：模型是否形成错误提案、执行器是否执行越权动作、最终状态是否满足用户目标。挡住发送到外部地址，并不意味着没有把错误信息写进一个获授权的草稿。

定义 1.1 能力许可用三元组 $(\text{operation}, \text{resource}, \text{scope})$ 表示，例如读指定公开文档、写指定草稿。权限谓词 $C(a)$ 判断动作是否落在许可内；语义目标谓词 $T(s)$ 判断最终状态是否完成用户任务。$C(a) = 1$ 不推出 $T(F(s, a)) = 1$。

给一个原创例子：用户授权整理公开会议安排。代理被页面文字诱导把会议时间改成错误值，仍只写入获授权草稿。操作权限全部合法，任务仍失败。另一个提案读取不相关私密文件，则可由执行器直接拒绝。前者需要来源与事实校验，后者需要权限约束，两种防线测量不同事件。

1.2 自适应攻击的分母是什么

官方报告使用每个环境最多 100 次尝试的自适应攻击，并报告该协议中的约 1% 攻击成功率；系统同时涉及模型训练、输入分类与干预、专家红队。这个结果属于整个评估配置，不能只归因于一个模型，也不能解释成任意单次恶意网页只有 1% 危险。

命题 1.2 *若每次攻击独立且有同样成功概率 p，N 次中至少一次成功的概率为 $q_N = 1 - (1-p)^N$。不需要独立时仍有 $\Pr(\bigcup_i E_i) \le \sum_i \Pr(E_i)$，但后式通常不是精确值。*

证明. 独立时全部失败概率为 $(1-p)^N$，取补事件。一般情况使用并集上界；事件可能重叠，所以把概率相加只能得上界。 □

例题 1.1 若单次独立失败概率为 0.001，100 次至少一次失败约为 0.0952。若某协议的 100 次汇总成功率为 0.01，在独立同分布的额外假设下才可反解 $p = 1 - 0.99^{1/100} \approx 0.0001005$。真实攻击会根据之前结果调整，既不独立也不同分布，所以不能用这个反解估计实际单次风险。

这里还要明确单位：每个环境是否重置、每次是否重新抽任务、成功判定看输出还是实际状态、攻击者能修改哪些观察、是否能看模型轨迹。缺少这些信息，两个 ASR 数字即使相近也不一定可比。

1.3 把防线拆成可检验条件

模型训练可以改变提案分布；分类器可以给观察附风险标记；干预可改变代理后续行为；执行器可以拒绝超出许可的操作。设恶意观察为 M，模型提出越权动作是 P，执行器放行为 X。当 $\Pr(M) > 0$ 且 $\Pr(P \mid M) > 0$ 时，实际越权概率为

$$\Pr(P \cap X \mid M) = \Pr(P \mid M) \Pr(X \mid P, M).$$

这是条件概率恒等式，不需要两道防线独立。若 $\Pr(P \mid M) = 0$，越权概率直接为零，无需定义第二因子。若只测 $\Pr(P \mid M)$，没有评价执行器；若只测实际执行，没有知道模型是否在不停提出危险动作。声称“两道防线各降低十倍，合起来一百倍”需要证明条件错误率，而不能将边际错误率机械相乘。

输入扫描若漏检某观察，并不意味着执行必然出错。输入扫描若命中，也可能误拒正常资料。应同时记录真攻击执行率、正常任务完成率、误拒、延迟和费用；任务全拒绝给零 ASR，却没有可用代理。

1.4 我们的实际权限与误拒实验

`results/v03-research/metrics.json` 保留全部四种符号策略的结果。对 120 个攻击案例，来源盲策略执行 80 个越权动作且产生 120 个语义失败；加许可执行器后越权执行变成零，但语义失败仍有 40 个。关键词拒绝没有语义攻击成功，却把正常完成率降到 0.5。理想来源路由器在有限案例中保持正常完成并抵御全部攻击。这个最后结果由模拟器的完整规则保证，不能移植为真实语言理解能力。

多步模拟另设每步基础错误率 0.08，错误后状态吸收，八步成功的理论值为 $0.92^8 \approx 0.5132$，10,000 条实际轨迹的成功率为 0.5150。加入指定恢复与误拒机制后，实际成功率为 0.6569。这些数来自实际执行，但错误率和独立假设是人工规定；它说明多步任务需要测轨迹而非只平均局部准确率，未测任何公司代理的真实行为。

1.5 一个可复核浏览器研究协议

先建立沙盒页面与本地文件，所有收件人和目的地均为模拟对象。冻结正常任务集合、允许动作集合、成功判定和攻击预算。正常任务覆盖只读与写草稿；攻击覆盖目标改变、角色伪装和无关动作诱导。把攻击者可见信息写进协议，再比较无防线、仅模型提示、仅执行器、完整系统四组。测试过程保存每步观察、提案、许可判断和状态差异，最后由独立程序判定目标是否实现。

该设计避免把“模型说自己抵御了攻击”当证据。对实际系统，还应报告跨网页模板、跨任务与跨攻击者的留出结果；真实网页里的脚本、视觉和动态加载超出这套文本沙盒。第一次小研究可以只研究文本，但标题和结论必须写出这个范围。

习题 1.1 所有越权执行都被阻止，能否得出代理任务安全完成？给一个许可内失败例子。

解答. 不能。代理可把来自恶意页面的错误地址写到授权报告，动作在许可内而事实错误。权限验证与目标、事实核验应分别测量。 □

习题 1.2 在 200 个独立环境中零次攻击成功，能否声称真实成功率是零?

解答. 不能。若各环境独立同分布，真实成功率 q 下观察零次的概率为 $(1-q)^{200}$。解 $(1-q)^{200}=0.05$，得到单侧 95% 上界约 0.0149。若环境相关或被选择过，这个统计范围也未必有效。 □

参考文献

[1] Anthropic. Mitigating the risk of prompt injections in browser use. 2025-11-24. https://www.anthropic.com/research/prompt-injection-defenses.